1. (5 Punkte) Die Kryptologie unterscheidet die vier Sicherheitsziele *Vertraulichkeit*, *Integrität*, *Authentizität* und *Verbindlichkeit*.
   a. Erläutere kurz, was mit den Sicherheitszielen *Integrität* und *Verbindlichkeit* gemeint ist.
   b. Ordne den folgenden Situationen jeweils das verletzte Sicherheitsziel zu:
      (1) Eve liest eine unverschlüsselte E-Mail von Alice an Bob mit.
      (2) Mallory fängt eine Überweisung ab und ändert den Empfänger.
      (3) Mallory schickt Bob eine Bestellung, die scheinbar von Alice stammt.
      (4) Alice bestreitet nachträglich, einen von ihr verschickten Vertrag verfasst zu haben.

Lösung: a. *Integrität*: Die empfangene Nachricht wurde von keiner dritten Person unbemerkt verändert (manipuliert).
Verbindlichkeit: Der Urheber einer Nachricht kann nachträglich nicht bestreiten, sie verfasst zu haben.
b. (1) Vertraulichkeit (2) Integrität (3) Authentizität (4) Verbindlichkeit

2. (3 Punkte) Erläutere den Unterschied zwischen symmetrischer und asymmetrischer Verschlüsselung.

Lösung:

Bei der symmetrischen Verschlüsselung wird für das Ver- und Entschlüsseln nur ein Schlüssel verwendet. Der Schlüssel muss entweder persönlich oder mit Hilfe eines abhörsicheren Kanals vom Sender zum Empfänger übertragen werden. Bei der asymmetrischen Verschlüsselung gibt es zwei Schlüssel, einen privaten und einen öffentlichen Schlüssel, der letztere ist allen möglichen Kommunikationspartnern bekannt. Der private Schlüssel wird nie veröffentlicht, der öffentliche Schlüssel kann über alle zur Verfügung stehenden Publikationsmöglichkeiten veröffentlicht werden (E-Mail, WWW-Seiten, Public-Key-Server, ...). Um die Echtheit eines öffentlichen Schlüssels zu überprüfen, muss es ein Verfahren zur Herstellung von Schlüsselvertrauen geben. Das kann eine (zentrale) Zertifizierungsstelle sein oder ein dezentraler Web-of-Trust-Ansatz.

3. (2 Punkte) Du willst zur Sicherheit die Daten deiner Festplatte verschlüsseln. Gib an, ob du ein symmetrisches oder asymmetrisches Verschlüsselungsverfahren wählen würdest. Begründe deine Wahl.

Lösung: Bei der Verschlüsselung einer Festplatte ist es wichtig, dass die verschlüsselten Daten schnell ausgelesen werden können, um die Arbeitsgeschwindigkeit nicht zu beeinträchtigen. Der Schlüsselaustausch ist nicht relevant, da sowohl der Empfänger als auch der Sender ein und dieselbe Person sind. Deshalb ist ein symmetrisches Verfahren vorzuziehen.

4. (3 Punkte) Ein Verein möchte Nachrichten nur noch mit asymmetrischer Verschlüsselung per email empfangen. Deshalb soll der Webmaster, der Zugriff auf den Mailserver hat, den öffentlichen Schlüssel auf der Homepage des Vereins veröffentlichen. Erläutere, wie der Webmaster mit Hilfe eines sogenannten *Man-in-the-Middle-Angriffs* die Nachrichten manipulieren kann.

Lösung: Der Webmaster veröffentlicht seinen eigenen öffentlichen Schlüssel an Stelle des öffentlichen Schlüssels des Vereins auf deren Homepage. Wenn ein Kunde mit Hilfe dieses Schlüssels eine Nachricht an den Verein schickt, fängt der Webmaster die Mail auf dem Mailserver ab, entschlüsselt sie mit Hilfe seines privaten Schlüssels, manipuliert die Nachricht und schickt sie dann mit Hilfe des öffentlichen Schlüssels des Vereins an den Verein weiter.

5. (4 Punkte) Die Sicherheit des RSA-Verfahrens beruht darauf, dass das Produkt $m = p \cdot q$ zweier großer Primzahlen zwar leicht zu berechnen, aber praktisch nicht wieder in seine Primfaktoren zu zerlegen ist.
   (a) Erkläre, was man unter einer *Einwegfunktion* versteht, und nenne die Einwegfunktion beim RSA-Verfahren.
   (b) Das Zerlegen einer Zahl mit 16 Stellen dauert auf einem Rechner etwa 1 Sekunde. Mit je zwei Stellen mehr wird die Rechenzeit zehnmal so lang. Wie lange dauert es ungefähr bei 26 Stellen?
   (c) Warum benutzt man in der Praxis Zahlen mit mehr als 600 Stellen?

Lösung: a) Eine Einwegfunktion lässt sich in einer Richtung leicht berechnen, die Umkehrung gelingt aber praktisch nicht in vertretbarer Zeit. Bei RSA ist das die Multiplikation zweier Primzahlen.
b) 10 Stellen mehr sind fünfmal der Faktor 10, also 10^5 Sekunden, das ist mehr als ein Tag.
c) Für alle bekannten Angriffe wächst die Laufzeit so stark mit der Stellenzahl, dass ein Angriff bei so langen Zahlen praktisch nicht gelingt.

6. (5 Punkte) Alice möchte Bob eine öffentlich lesbare Nachricht n schicken und diese so *signieren*, dass Bob sicher sein kann, dass die Nachricht wirklich von Alice stammt und unterwegs nicht verändert wurde. Alice und Bob besitzen jeweils ein Schlüsselpaar eines asymmetrischen Verfahrens; zusätzlich ist eine kryptographische Hashfunktion h öffentlich bekannt.
   a. Beschreibe, welche Schritte Alice ausführt, um zur Nachricht n die Signatur s zu erzeugen.
   b. Beschreibe, wie Bob mit Hilfe von n und s prüft, ob die Signatur gültig ist.
   c. Begründe, warum ein Angreifer die signierte Nachricht nicht unbemerkt ändern und warum er auch keine neue Nachricht im Namen von Alice signieren kann.

Lösung: a. Alice berechnet den Hashwert $h(n)$ der Nachricht und verschlüsselt diesen mit ihrem *privaten* Schlüssel. Das Ergebnis ist die Signatur s. Sie schickt n und s an Bob.
b. Bob entschlüsselt s mit dem *öffentlichen* Schlüssel von Alice und erhält so den von Alice gebildeten Hashwert. Er berechnet selbst $h(n)$ aus der empfangenen Nachricht und vergleicht beide Werte. Stimmen sie überein, ist die Signatur gültig.
c. Ändert der Angreifer n, so passt der neu berechnete Hashwert $h(n)$ nicht mehr zu dem in s verschlüsselten Hashwert (Integrität). Eine passende Signatur zu einer veränderten oder neuen Nachricht kann er nicht erzeugen, da er den privaten Schlüssel von Alice nicht kennt (Authentizität, Verbindlichkeit).

7. (5 Punkte) Beim asymmetrischen Verfahren muss sichergestellt sein, dass ein öffentlicher Schlüssel wirklich zu der Person (oder dem Server) gehört, die ihn präsentiert. Dazu dient eine *Public-Key-Infrastruktur* (PKI) mit Zertifikaten, die von einem Trust-Center ausgestellt werden.
   a. Erläutere, welches Problem ein Zertifikat löst und wie ein Trust-Center dabei vorgeht.
   b. Nenne zwei Anwendungsbereiche von Public-Key-Infrastrukturen aus dem Alltag.
   c. Bewerte einen Sicherheitsaspekt: Was passiert, wenn der private Schlüssel eines Trust-Centers in falsche Hände gerät?

Lösung: a. Ein Zertifikat bestätigt die *Authentizität* eines öffentlichen Schlüssels, also die Zuordnung Schlüssel ↔ Inhaber. Das Trust-Center prüft die Identität des Antragstellers und signiert dann dessen öffentlichen Schlüssel zusammen mit den Inhaberdaten mit seinem eigenen privaten Schlüssel. Wer dem Trust-Center vertraut und dessen öffentlichen Schlüssel kennt, kann das Zertifikat prüfen.
b. Zum Beispiel: Transportverschlüsselung im Web (HTTPS / TLS-Zertifikate), Mailverschlüsselung (S/MIME), digitaler Personalausweis, Signaturkarten.
c. Dann kann der Angreifer beliebige gefälschte Zertifikate ausstellen und sich als jede beliebige Stelle ausgeben (Man-in-the-Middle). Das Vertrauen in alle von diesem Trust-Center ausgestellten Zertifikate ist zerstört; sie müssen zurückgezogen werden.

8. (4 Punkte) Eine Schule setzt ein Informatiksystem ein, in dem Noten, Fehlzeiten und Kontaktdaten der Schülerinnen und Schüler gespeichert werden.
   a. Erläutere je zwei technische und zwei organisatorische Maßnahmen, mit denen die Datensicherheit dieses Systems gewährleistet werden kann.
   b. Erläutere den Unterschied zwischen *Datensicherheit* und *Datenschutz* an diesem Beispiel.

Lösung: a. Technisch z. B.: verschlüsselte Speicherung und verschlüsselte Übertragung (HTTPS), Zugriffskontrolle mit persönlichen Benutzerkonten und starken Passwörtern / Mehrfaktorauthentifizierung, regelmäßige Sicherungskopien (Backups), aktuelle Software / Sicherheitsupdates.
Organisatorisch z. B.: Rollen- und Rechtekonzept (Lehrkraft sieht nur die eigenen Klassen), Schulung der Mitarbeitenden, klare Regeln zur Weitergabe und Löschung von Daten, protokollierte Zugriffe.
b. *Datensicherheit*: Schutz der Daten vor Verlust, Manipulation und unbefugtem Zugriff (unabhängig davon, um welche Daten es sich handelt). *Datenschutz*: Schutz des Rechts der betroffenen Personen auf informationelle Selbstbestimmung – es dürfen nur die wirklich nötigen personenbezogenen Daten für einen festgelegten Zweck erhoben und verarbeitet werden.

9. (5 Punkte) „Datensicherheit schützt Daten vor unbefugtem Zugriff – ist das dann nicht dasselbe wie Datenschutz?“
a. Erläutere den Kernunterschied zwischen *Datensicherheit* und *Datenschutz*. Gehe darauf ein, *was* jeweils geschützt wird und *welche Daten* jeweils betroffen sind.
b. Begründe die Aussage: „Datensicherheit ist eine Voraussetzung für Datenschutz, aber allein nicht ausreichend.“
c. Ordne jeder Situation zu, ob *Datensicherheit*, *Datenschutz* oder *beides* betroffen ist:
(1) Eine Firma sichert die Baupläne eines neuen Produkts gegen Diebstahl.
(2) Ein Online-Shop schützt die gespeicherten Namen und Adressen seiner Kunden vor Hackern und verwendet sie nur zur Bestellabwicklung.
(3) Eine Schule speichert die Fingerabdrücke aller Schülerinnen und Schüler in einer hervorragend abgesicherten Datenbank.

Lösung: a. *Datensicherheit* schützt **Daten** (alle Daten) vor Verlust, Manipulation und unbefugtem Zugriff – im Mittelpunkt stehen technische und organisatorische Maßnahmen. *Datenschutz* schützt **Menschen und ihre Persönlichkeitsrechte** und betrifft nur **personenbezogene** Daten – im Mittelpunkt steht die rechtmäßige Erhebung, Verarbeitung und Nutzung. Datensicherheit fragt „Sind die Daten geschützt?“, Datenschutz fragt „Dürfen diese Daten überhaupt erhoben und verwendet werden?“
b. Sind personenbezogene Daten nicht ausreichend gesichert, können sie abfließen oder manipuliert werden – Datenschutz ist dann nicht mehr gewährleistet. Umgekehrt kann eine perfekt gesicherte Datenbank trotzdem gegen den Datenschutz verstoßen, wenn die Daten ohne Rechtsgrundlage bzw. Einwilligung erhoben oder weitergegeben werden.
c. (1) nur Datensicherheit (keine personenbezogenen Daten). (2) beides (Schutz vor Hackern = Datensicherheit; Zweckbindung = Datenschutz). (3) Datensicherheit erfüllt, Datenschutz möglicherweise verletzt, da die Erhebung der Fingerabdrücke evtl. gar nicht zulässig ist.

10. (4 Punkte) Ein Anbieter einer kostenlosen Fitness-App speichert dauerhaft Standort, Puls, Schlafzeiten und Bewegungsprofile aller Nutzerinnen und Nutzer und wertet diese zentral aus.
a. Nenne zwei Gründe, warum die massenhafte Erhebung und Speicherung dieser Daten für die Betroffenen problematisch sein kann.
b. Beurteile das Geschäftsmodell „kostenlose App gegen Daten“ und nenne zwei Maßnahmen, mit denen die Datenverarbeitung datensparsamer gestaltet werden könnte.

Lösung: a. Zum Beispiel: Aus den Bewegungsprofilen lassen sich Wohnort, Arbeitsplatz und Tagesablauf ableiten (Rückschlüsse auf einzelne Personen trotz „anonymer“ Speicherung). Gesundheitsdaten sind besonders sensibel und können bei Weitergabe an Dritte (Versicherungen, Arbeitgeber) oder bei einem Datenleck missbraucht werden. Die Daten können mit anderen Datenquellen zusammengeführt werden; eine spätere Zweckänderung ist für die Betroffenen kaum kontrollierbar.
b. Die Nutzung ist nur scheinbar kostenlos – bezahlt wird mit persönlichen Daten, deren Wert und spätere Verwendung die Nutzenden nicht überblicken. Datensparsamer wäre z. B.: nur die wirklich benötigten Daten erheben, Auswertung lokal auf dem Gerät statt zentral, frühzeitige Löschung bzw. Speicherung nur in aggregierter Form, echte Einwilligung mit klarer Zweckbindung.